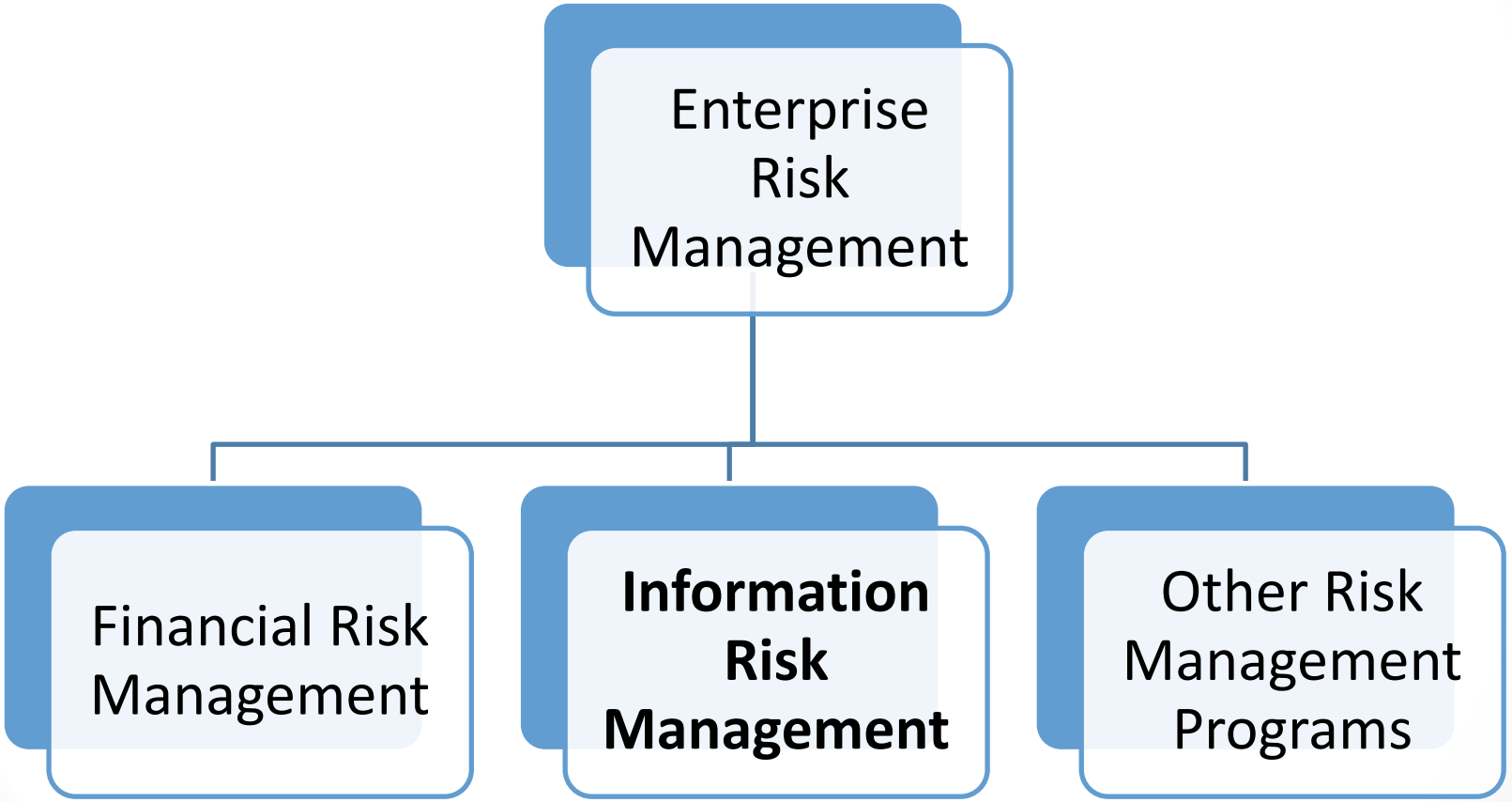
Information Risk Management: An Introduction

By **Kavinga Yapa Abeywardena**

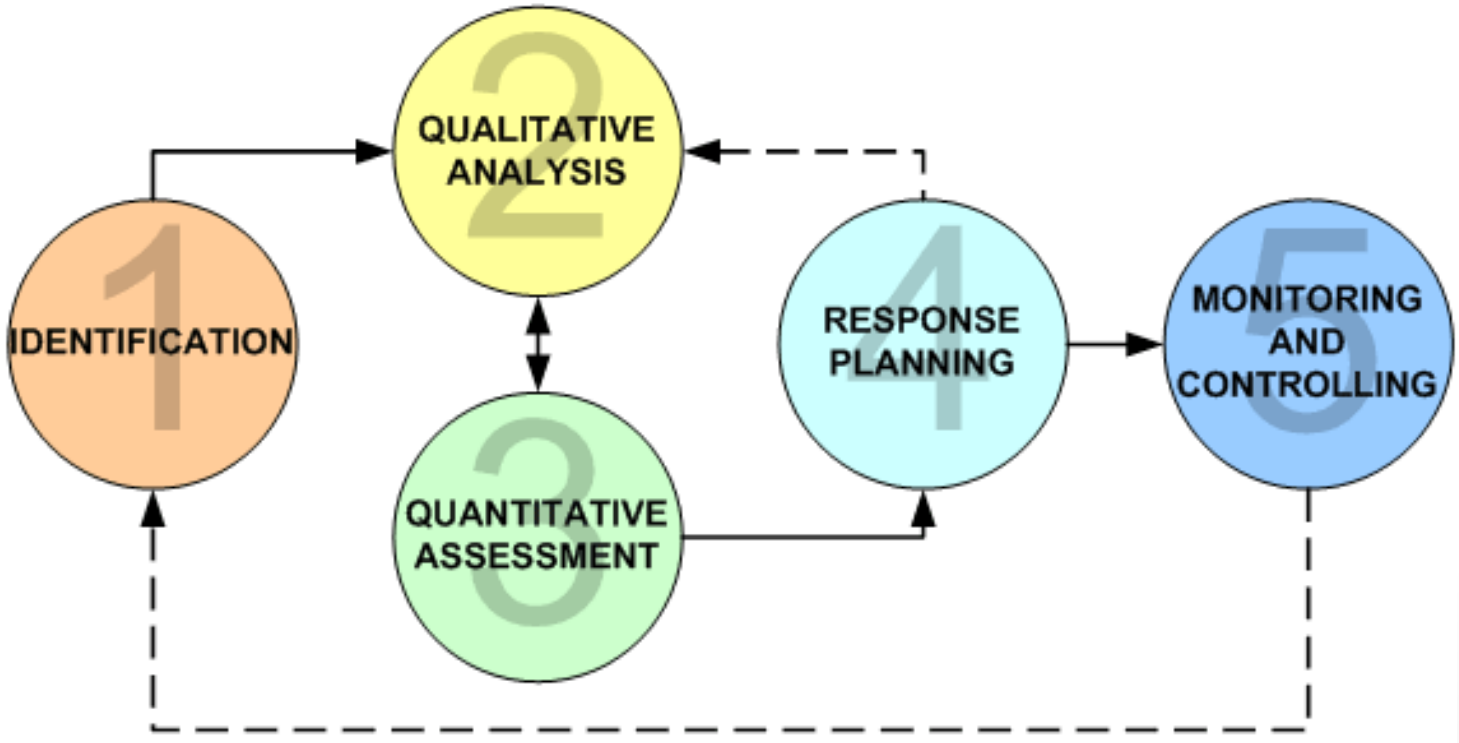
Sri Lanka Institute of Information Technology (SLIIT)

THE BIG PICTURE



Risk Management Process

5-step Risk Management Approach



Risk Management Process

Step 1 : Risk Identification

- Consider internal & external factors
- Use expert knowledge (Penetration Testing?)
- Involve every department
- Creativity & Imagination is the KEY!
- Risk identification and review is an ongoing process throughout the project's lifetime.

Risk Management Process

Step 2 : Qualitative Analysis

- Identifies the most critical risks and focus the attention
- Impact rating depend on company's business goals & objectives
  - Reputation/customer confidence
  - Life/health of customer
  - Fines/Legal penalties
  - Financial
  - Other

Risk Management Process

Step 2 : Qualitative Analysis

- Use expert knowledge & judgment
- Probability of an event occurring identified
- Risk = Impact x Probability
- Example Case Study:
  - https://www.dropbox.com/s/k0i1d104ihfi5go/LCS%20-%20IT%20Security%20Report.pdf?dl=0
- Discussion!

Risk Management Process

Step 2 : Qualitative Analysis (Example)

PROBABILITY		
Qualitative Scale	**Numeric Scale**	**Description**
Very Low	1	Unlikely to occur
Low	4	May occur occasionally
Medium/Moderate	6	Is as likely as not to occur
High	8	Is likely to occur
Very High	10	Is almost certain to occur

Risk Management Process

Step 2 : Qualitative Analysis (Example)

IMPACT		
Qualitative Scale	**Numeric Scale**	**Description**
Very Low	1	Negligible impact
Low	2	Minor impact on time, cost or quality
Medium/Moderate	4	Notable impact on time, cost or quality
High	8	Substantial impact on time, cost or quality
Very High	16	Threatens the success of the company

Risk Management Process

IMPACT	COST	TIME	QUALITY
Very low	Manageable by fund transfer from another sector	Slight slippage against internal targets	Slight reduction in quality/scope with no overall impact on usability/standards
Low	Additional Funding required	Slight slippage against key milestones or published targets	Failure to include certain 'nice to have' elements promised to stakeholders
Moderate	Significant additional Funding required	Delay affects key stakeholders and causes loss of confidence in the project	Significant elements of scope or functionality will be unavailable
High	Significant reallocation of owner's funds (or borrowing) required to achieve business goals	Failure to meet key deadlines in relation to the strategic plan	Failure to meet the needs of a large proportion of stakeholders
Very high	Threaten the existence of the business (Can be beyond recovery)	Delay jeopardizes the existence of the business	Products or services become effectively unusable

Risk Management Process

Step 2 : Qualitative Analysis (Example)

Risk	Probability	Impact	Rating
A	4	8	32
B	6	2	12
C	1	16	16

Risks sorted according to rating : **A > C > B**

Proximity: Immediate nature of the risk to be taken into consideration. How to incorporate?

Risk Management Process

Step 3 : Quantitative Analysis

- Qualitative analysis is only useful as long as the management agrees on ratings & what they actually mean. (E.g. What is a rating of 16? in $?)
- In order to analyse risks in a meaningful way it is necessary to define the impacts in relation to company's business goals.
- What's the difference of 'very low' & 'moderate' ?

Quantitative Risk Analysis

- So far we have focused on ‘Qualitative Risk Analysis’.
- We have noticed that Qualitative methods are scenario based.
- **‘Quantitative Risk Analysis’** attempts to assign independent monetary values to system components.
- Quantitative methods tend to be more resource consuming, however they come with few distinct **advantages** over qualitative methods.

Quantitative Risk Analysis: Key Variables

- **Exposure Factor(EF)** = Percentage of asset loss caused by identified threat (0-100%)
- **Single Loss Expectancy (SLE)** = Asset Value x EF
  e.g. Rs. 50,000 x 20% = Rs. 10,000
- **Annualized Rate of Occurrence (ARO)** = Frequency a threat will occur within a year
- **Annualized Loss Expectancy (ALE)** = SLE x ARO
- **Safeguard Cost/Benefit** = ALE before Safeguard - ALE After Safeguard - Annual Cost of Safeguard

Determining Asset Values [2]

- **Tangible Assets**
  - Ask the **IT manager** for cost information regarding existing equipment, hardware & software
  - Internet **research** on exact or comparable systems
  - Look at **previous projects**, adjust according to depreciation
  - Overall **replacement cost** due to failure (installation, troubleshooting, 10% for contingency, temporary loss of services)

- **Intangible Assets**
  - Measure asset's fair market value (depreciation!) e.g. Trade Secrets
  - Focus on the income producing capability of the intangible asset
  - Involve senior management to conduct final valuation

Risk Management Process

Step 4 : Response Planning

- Individual risks to be treated according to the impact rating from previous analysis
- Different responses for different risks
- All responses carry a cost (time, money & labor)
- Use expert knowledge & judgment
- Involve company's stakeholders

Risk Management Process

Step 4 : Response Planning: Standard Levels of Response

RESPONSE	DESCRIPTION
Avoid	Risk Removal and Risk Prevention. Altering the plan so that the circumstances which may give rise to the risk no longer exist.
Mitigate	Risk Reduction. Reducing the probability or impact of the risk.
Transfer	Moving the impact (and ownership) of the risk to a third party.
Defer	Deferring aspects of the plan to a date when the risk is less likely to occur.
Accept	Dealing with the risk via contingency rather than altering the plan.

Risk Management Process

Step 5 : Monitor & Control Risks

- Keep track of the identified risks, monitor the **effectiveness** of risk responses
- Identify new or changed risks (Back to Step 2 - 4)
- A regular review & updating process is required
- Communication with all the stakeholders
- Phase out or release of contingency responses if risks no longer exist

Risk Management Methodologies

- There are variety of methodologies available for Information Risk Management. Some are well documented, others not so much.
- We will specifically look at **OCTAVE / OCTAVE-Allegro**
- **Next Lecture!**

QUESTIONS ?




Thank
You